

## BUSINESS OVERVIEW

# VulnScan Toolkit

Faster, Consistent, Auditable Web Vulnerability Assessments

---

Innovation Project Proposal · July 2026 · CIESC

Prepared by: Higor Silva

## 1. The Problem

---

Web application security assessments today rely on running several independent open-source tools by hand — one for SQL injection, another for cross-site scripting, another for general misconfiguration checks. Each tool has its own command syntax, output format, and severity scale. Analysts spend a disproportionate share of their time on manual, repetitive work: launching tools one at a time, waiting on results, translating inconsistent output into a shared vocabulary, and manually assembling a report before any finding reaches a decision-maker.

This creates three recurring costs for the organization: slower turnaround on security assessments, inconsistent report quality depending on which analyst ran the scan, and a real risk of misconfigured or unauthorized scans being run against the wrong target.

## 2. The Solution

---

VulnScan Toolkit is a single, containerized command that orchestrates multiple industry-standard open-source scanners (sqlmap, OWASP ZAP, Nikto, Nuclei) and automatically produces one consolidated, professional report — in HTML and PDF — with an executive summary, criticality scoring aligned to the industry-standard CVSS framework, technical evidence for each finding, and concrete mitigation guidance.

Instead of an analyst running four tools and writing a report by hand, one command produces a standardized deliverable in a fraction of the time, every time.

## 3. Key Benefits

---

| Benefit             | Impact                                                                                                                 |
|---------------------|------------------------------------------------------------------------------------------------------------------------|
| Time savings        | Replaces hours of manual tool execution and report assembly with a single automated run                                |
| Consistency         | Every report follows the same structure and severity scale, regardless of who runs the scan                            |
| Built-in guardrails | An allowlist-based scope control blocks scans against unauthorized targets by design                                   |
| Zero licensing cost | Built entirely on established, actively-maintained open-source tools — no per-seat or per-scan licensing fees          |
| Portable & isolated | Ships as a Docker container; runs identically on any machine without conflicting with existing tools (e.g. Kali Linux) |
| Extensible          | Modular design — new vulnerability classes/tools can be added without reworking the core system                        |

## 4. Who Benefits

- **Security / IT teams** — faster assessment cycles, more time for deep manual analysis instead of tool babysitting.
- **Management** — a standardized, board-ready report format with an executive summary that does not require technical background to interpret at a high level.
- **Development teams** — clear, actionable mitigation recommendations tied to specific endpoints and parameters, reducing back-and-forth on vague findings.

## 5. Positioning vs. Alternatives

| Approach                   | Cost                                  | Consistency                     | Speed |
|----------------------------|---------------------------------------|---------------------------------|-------|
| Manual multi-tool scanning | Analyst time only                     | Low — depends on the individual | Slow  |
| Commercial DAST platforms  | High licensing cost                   | High                            | Fast  |
| <b>VulnScan Toolkit</b>    | No licensing cost (open-source stack) | High — standardized pipeline    | Fast  |

VulnScan Toolkit targets the middle ground: the consistency and speed benefits typically associated with commercial platforms, built on a zero-license-cost open-source foundation, tailored to the organization's own scope and workflow.

## 6. Current Status & Next Steps

The core system (orchestrator, normalized data model, report engine) and four scanning modules covering reconnaissance, SQL Injection, XSS, and XXE are implemented as a working MVP. The roadmap ahead focuses on parallelizing scans for speed, expanding module coverage, and refining the report for broader stakeholder consumption (including a non-technical summary view and visual severity charts).

This project is presented as an internal innovation initiative: a practical demonstration of how existing open-source security tooling can be consolidated into an efficient, reusable internal capability, at no licensing cost, with security and authorization controls built in from day one.